

NIST SP 800-53 Rev. 5

Security and Privacy Controls for
Information Systems and Organizations

Table of Contents

Abstract	3
Keywords	3
Errata	18
INTRODUCTION	27
1.1 PURPOSE AND APPLICABILITY	28
1.2 TARGET AUDIENCE	29
1.3 ORGANIZATIONAL RESPONSIBILITIES	29
1.4 RELATIONSHIP TO OTHER PUBLICATIONS	31
1.5 REVISIONS AND EXTENSIONS	31
1.6 PUBLICATION ORGANIZATION	31
THE FUNDAMENTALS	33
2.1 REQUIREMENTS AND CONTROLS	33
2.2 CONTROL STRUCTURE AND ORGANIZATION	34
2.3 CONTROL IMPLEMENTATION APPROACHES	37
2.4 SECURITY AND PRIVACY CONTROLS	39
2.5 TRUSTWORTHINESS AND ASSURANCE	40
THE CONTROLS	42
3.1 ACCESS CONTROL	44
AC-1 POLICY AND PROCEDURES	44
AC-2 ACCOUNT MANAGEMENT	45
AC-3 ACCESS ENFORCEMENT	49
AC-4 INFORMATION FLOW ENFORCEMENT	54
AC-5 SEPARATION OF DUTIES	62
AC-6 LEAST PRIVILEGE	62

CHAPTER ONE: INTRODUCTION

1.1 PURPOSE AND APPLICABILITY

This publication provides a catalog of security and privacy controls for information systems and organizations to protect organizational operations and assets, individuals, other organizations, and the Nation from a diverse set of threats and risks including hostile attacks, human errors, natural disasters, structural failures, foreign intelligence entities, and privacy risks.

1.2 TARGET AUDIENCE

This publication is intended to serve a diverse group of individuals and organizations with security and privacy responsibilities including system owners, common control providers, authorizing officials, system security and privacy officers, and risk executives.

CHAPTER TWO: THE FUNDAMENTALS

2.1 REQUIREMENTS AND CONTROLS

Requirements are statements of security and privacy objectives that a system must achieve. Controls are the safeguards or countermeasures employed within a system to satisfy those requirements. The relationship between requirements and controls is fundamental to understanding how security and privacy objectives are translated into actionable technical and operational measures.

2.2 CONTROL STRUCTURE AND ORGANIZATION

Controls in this publication are organized into twenty control families. Each family contains controls related to the security or privacy functionality of the family. The control families are aligned with the seventeen security-related areas in FIPS 200 and the privacy areas from OMB Circular A-130.